

ÉTUDE DE CAS — SPOTIFY

GLOSSAIRE

Rôles, instances, acronymes et notions clés

Certification RNCP 41993 – Adrien COSSON

Bloc 1 - Concevoir et piloter la gouvernance des données et des systèmes d'IA

1. Rôles

Les rôles qui portent la gouvernance des données et de l'IA chez Spotify, avec leur rattachement. Les définitions reprennent celles de la politique (Livable 2) et de l'organigramme (Livable 2b).

- **CDO (Chief Data Officer)** : pilote la stratégie de gouvernance, définit les politiques en lien avec les objectifs métier et anime le Centre d'Excellence (standards, catalogue, outils, formation). Rapporte directement à la direction générale.
- **DPO (Data Protection Officer, délégué à la protection des données)** : garant de la conformité RGPD et CCPA, interlocuteur de l'IMY. Conseille sur les DPIA, supervise les violations de données et les demandes des utilisateurs. Rattaché à la direction générale et ne reçoit aucune instruction sur ses missions (RGPD art. 38).
- **Data Owner** : responsable métier des données d'un domaine. Il les classe (Public à Restreint) et décide qui y accède. Ex. : Marketing Director pour les données marketing, Product Managers pour les données produit.
- **Data Steward** : au quotidien dans chaque département, garantit l'exactitude, la cohérence et la fiabilité des données, les documente dans le catalogue, applique la politique et gère les accès. Rapporte au Data Owner, lien fonctionnel avec le CDO dont il applique les standards.
- **Model Owner** : responsable d'un modèle d'IA sur tout son cycle de vie : origine et licéité des données d'entraînement, reproductibilité, explicabilité, contrôle des biais avant chaque mise en ligne, suivi en production. Rattaché au Développement produit (moteur de recommandation).
- **Head of Engineering (CIO/CTO)** : met en œuvre les contrôles techniques (sécurité, chiffrement, journalisation, intégration) et garantit une infrastructure conforme. Aujourd'hui seul responsable de la sécurité (défi C5).
- **Data Engineers** : construisent les pipelines, connectent les systèmes aux outils de gouvernance et mettent en place les contrôles automatiques. Rattachés au Head of Engineering.
- **Équipe juridique** : valide les politiques, assure la veille réglementaire avec le DPO et encadre les contrats avec les sous-traitants.
- **Chef de projet du pilote** : coordonne le pilote de 6 mois, suit les indicateurs et rend compte au Comité. Rattaché au CDO.

2. Instances

- **Direction générale (DG)** : sponsor de la gouvernance. Le CDO, le DPO et le Head of Engineering y sont rattachés.
- **COMEX (comité exécutif)** : instance dirigeante à qui s'adresse la présentation (Livable 4). Valide la politique, lance le pilote et nomme les rôles.
- **Comité de gouvernance des données** : instance transverse et non hiérarchique, réunie chaque mois avec des représentants des départements. Valide les politiques, arbitre les sujets entre départements, accorde les exceptions et décide du passage d'une phase à la suivante.
- **Centre d'Excellence (CoE)** : équipe centrale dirigée par le CDO qui fixe les règles et fournit les outils, tandis que chaque département reste responsable de ses données.

3. Acronymes

- **ABAC (Attribute-Based Access Control)** : contrôle d'accès selon des attributs, ici l'étiquette de sensibilité de la donnée. Affine le RBAC.
- **AI Act** : règlement européen sur l'intelligence artificielle (UE 2024/1689). Classe les systèmes d'IA par niveau de risque (inacceptable, élevé, limité, minimal) et impose de signaler les contenus générés par IA.
- **BC** : business case, le cas d'étude Spotify fourni par Jedha.
- **BI (Business Intelligence)** : analyse et restitution des données pour la décision (tableaux de bord, reporting).
- **CA** : chiffre d'affaires. Base du plafond des amendes RGPD (4 % du CA mondial).
- **CCPA (California Consumer Privacy Act)** : loi californienne sur la vie privée. Droit de savoir, de supprimer et de refuser la vente de ses données, sans discrimination.
- **CDO (Chief Data Officer)** : directeur des données (voir Rôles).
- **CIO (Chief Information Officer)** : directeur des systèmes d'information.
- **CoE (Centre of Excellence)** : Centre d'Excellence (voir Instances).
- **COMEX** : comité exécutif (voir Instances).

- **CPRA (California Privacy Rights Act)** : loi de 2020 qui renforce le CCPA.
- **CTO (Chief Technology Officer)** : directeur technique.
- **DG** : direction générale.
- **DMBOK (Data Management Body of Knowledge)** : référentiel de la gestion des données publié par DAMA International, en 11 domaines. Source de la dimension « Métadonnées » ajoutée au diagnostic.
- **DPIA (Data Protection Impact Assessment, AIPD en français)** : analyse d'impact obligatoire avant un traitement à risque élevé pour les personnes (RGPD art. 35).
- **DPO (Data Protection Officer)** : délégué à la protection des données (voir Rôles).
- **DSAR (Data Subject Access Request)** : demande d'un utilisateur pour exercer ses droits (accès, suppression). Réponse sous un mois selon le RGPD ; cœur du pilote.
- **IA** : intelligence artificielle.
- **IMY (Integritetsskyddsmyndigheten)** : autorité suédoise de protection des données, équivalent de la CNIL. A sanctionné Spotify d'environ 5 M€ en juin 2023.
- **KPI (Key Performance Indicator)** : indicateur de succès.
- **MDM (Master Data Management)** : gestion des données de référence dans un référentiel maître unique.
- **PCI-DSS (Payment Card Industry Data Security Standard)** : norme de sécurité des données de carte bancaire, imposée par les réseaux de cartes (ce n'est pas une loi).
- **PDPA (Personal Data Protection Act)** : loi de Singapour sur les données personnelles.
- **PoC (Proof of Concept)** : preuve de concept, test court d'un outil avant de l'adopter.
- **Q&A (Questions & Answers)** : questions-réponses.
- **RACI (Responsible, Accountable, Consulted, Informed)** : matrice des responsabilités. R réalise, A approuve et rend compte (un seul par activité), C est consulté, I est informé.
- **RBAC (Role-Based Access Control)** : contrôle d'accès selon le rôle de la personne.
- **RGAA (Référentiel général d'amélioration de l'accessibilité)** : référentiel français d'accessibilité numérique.
- **RGPD (Règlement général sur la protection des données, GDPR en anglais)** : règlement européen sur les données personnelles. Violation notifiée sous 72 h, amende jusqu'à 4 % du CA mondial ou 20 M€.
- **RNCP (Répertoire national des certifications professionnelles)** : registre officiel français des certifications ; ici la certification 41993.

4. Notions clés

Gouvernance et maturité

- **Gouvernance des données** : règles, rôles et processus qui encadrent les données. Elle définit et contrôle.
- **Gestion des données** : mise en œuvre opérationnelle de ces règles (stockage, intégration, sécurité). Elle exécute.
- **Modèles d'organisation** : centralisé (une équipe décide de tout, risque de goulot d'étranglement), embarqué ou décentralisé (chaque équipe fait ses règles, risque de silos), Centre d'Excellence (règles au centre, responsabilité dans les départements).
- **Redevabilité (accountability)** : chaque donnée a un responsable identifié qui rend compte de son usage.
- **Échelle de maturité** : Aware (conscience du sujet), Reactive (on corrige quand un problème survient), Proactive (on anticipe), Managed (pilote et mesuré à l'échelle de l'entreprise), Effective (optimisé en continu). Spotify est à 2,7, cible Managed.
- **Défis C1 à C7** : silos, droits des utilisateurs, documentation, qualité, sécurité, IA, formation. Ils structurent les Livrables 2, 3 et 4.

Données et qualité

- **Silo de données** : données gérées par un département avec ses propres règles, sans lien avec les autres.
- **Identifiant utilisateur commun** : identifiant unique qui relie les données d'un même utilisateur dans tous les systèmes. Indispensable pour répondre complètement à une DSAR.
- **Métadonnées** : données qui décrivent les données (origine, propriétaire, format, sensibilité, fraîcheur).
- **Catalogue de données** : inventaire central des jeux de données, de leurs propriétaires et de leur niveau de sensibilité.
- **Lineage (lignage)** : traçabilité du parcours d'une donnée, de sa source à ses usages.

- **Marquage des données personnelles** : étiquetage dans le catalogue des données qui concernent une personne, pour savoir où elles se trouvent.
- **Data contract** : engagement de l'équipe qui produit une donnée sur son contenu, son format et sa qualité.
- **Qualité des données** : exactitude, complétude, cohérence, fraîcheur. Exemples du business case : préférences erronées, métadonnées obsolètes, doublons.
- **Data Lake / Data Warehouse** : le Data Lake stocke des données brutes de tout format ; le Data Warehouse des données structurées et préparées pour l'analyse.

Sécurité

- **Classification à 4 niveaux** : Public, Interne, Confidentiel, Restreint. Le niveau fixe qui accède, la durée de conservation et le partage possible.
- **Moindre privilège** : chacun n'accède qu'aux données strictement nécessaires à son travail.
- **Chiffrement** : rendre une donnée illisible sans la clé. Appliqué aux niveaux Confidentiel et Restreint.
- **Tokenisation** : remplacement du numéro de carte par un jeton chez le prestataire de paiement. Spotify ne stocke pas la carte, ce qui réduit le périmètre PCI-DSS.
- **Pseudonymisation** : remplacer l'identité par un pseudonyme. La personne reste ré-identifiable avec une information gardée à part, contrairement à l'anonymisation.

Conformité

- **Traitement licite et transparent** : chaque traitement a une base légale, et l'utilisateur sait clairement ce qui est fait de ses données.
- **Base légale** : fondement juridique d'un traitement (consentement, contrat, obligation légale, intérêt légitime...).
- **Consentement explicite** : accord libre, éclairé et donné par un acte positif, que l'utilisateur peut retirer.
- **Minimisation** : ne collecter et ne garder que les données nécessaires à la finalité.
- **Droits des utilisateurs** : accès, rectification, suppression, portabilité, opposition (RGPD) ; refus de la vente (CCPA).
- **Violation de données** : fuite, perte ou accès non autorisé. Notification à l'autorité sous 72 h.
- **Registre des traitements** : liste obligatoire des traitements de données personnelles (RGPD art. 30).
- **Sous-traitant** : prestataire qui traite des données pour le compte de Spotify, encadré par contrat.
- **Veille réglementaire** : suivi des évolutions des lois par le DPO et le juridique, présenté au Comité.

IA

- **Biais algorithmique** : erreur systématique d'un modèle qui désavantage un groupe (ex. des recommandations qui ignorent certains artistes ou publics).
- **Explicabilité** : capacité à expliquer pourquoi un modèle a produit un résultat (ex. pourquoi ce titre est recommandé).
- **Registre de modèles** : inventaire des modèles avec leurs versions, données d'entraînement et performances.

Pilote et changement

- **Pilote** : déploiement limité (6 mois, droits des utilisateurs en Suède) pour tester la gouvernance avant de l'étendre.
- **Conduite du changement** : formation, accompagnement et recueil des retours pour que les équipes adoptent les nouvelles règles.